

Mini Incident Response Plan

VORTEXTECH — Week 4 of 4 | Advanced Cyber Security Internship

1. Executive Summary

This document presents a structured incident response plan for a hypothetical data breach at **NovaCart**, a fictional online retail company. The incident involves an unsecured API endpoint that allowed unauthorized access to customer records. The response plan follows the six-phase NIST incident response lifecycle: *Preparation, Detection & Analysis, Containment, Eradication, Recovery, and Post-Incident Review (Lessons Learned)*.

2. Hypothetical Breach Scenario

Company	NovaCart — a fictional e-commerce platform storing customer account and order data.
Incident	A customer-facing API endpoint was misconfigured, failing to enforce server-side authorization. An attacker could retrieve other customers' records simply by modifying an identifier in the API request.
Discovery	An automated monitoring alert flagged an unusually high volume of database queries originating from the API. Analysts identified repeated requests accessing records outside the authenticated user's account.
Data at Risk	Customer names, email addresses, delivery addresses, order history, and internal customer IDs. Payment-card details are excluded — these are handled by a separate payment provider.
Root Cause	Missing server-side authorization checks and insufficient security testing of the API endpoint prior to deployment.

3. Incident Response Framework

The response is organized into the six phases of the NIST Incident Response Lifecycle.

3.1 Preparation

Before any incident occurs, NovaCart should maintain:

- A designated Incident Response Team (IRT) with clearly defined roles and contact details.
- Centralized logging, security monitoring, and automated alerting across all customer-facing services.
- Documented response procedures, asset inventories, and access-control policies.
- Regular backups of critical systems and databases, tested and stored securely.
- Periodic security testing of APIs and web services, with specific checks for broken access control.

3.2 Detection & Analysis

How the incident is identified and scoped:

- An automated alert fires on abnormal database query volume from the customer API.
- Security analysts validate the alert, confirm it is not a false positive, and identify the affected endpoint.
- API and database logs are reviewed to establish the timeframe of suspicious activity.
- The team determines which customer accounts or records were potentially accessed.
- All relevant logs and forensic evidence are preserved in an unaltered state for further investigation.

3.3 Containment

Immediate actions to prevent further unauthorized access:

- Access to the affected API endpoint is restricted; the endpoint is temporarily disabled if necessary.
- Associated API keys, session tokens, and credentials are revoked or rotated immediately.
- Affected servers or services are isolated from the broader network where required.
- Monitoring intensity is increased across related systems to detect any continued unauthorized activity.
- All containment actions, including timestamps and personnel involved, are documented.

3.4 Eradication

Removing the root cause from the environment:

- The API's server-side authorization logic is corrected so that every request is validated against the authenticated user's permissions and resource ownership.
- Any unauthorized access mechanisms, suspicious credentials, or malicious configuration changes identified during investigation are removed.
- The corrected endpoint undergoes thorough security testing — including access-control checks — before being returned to service.

3.5 Recovery

Restoring services safely after remediation:

- The corrected API endpoint is redeployed in a controlled, phased manner.
- The team verifies that authorization checks function correctly under realistic test conditions.
- System integrity is reviewed and confirmed before full traffic is restored.
- Enhanced monitoring continues post-restoration; recovery is declared complete only when normal operation is confirmed with no further signs of unauthorized access.

3.6 Post-Incident Review (Lessons Learned)

Structured reflection to strengthen future security posture:

- A formal post-incident review documents the full incident timeline, affected systems and data, detection and response actions taken, and confirmed root cause.
- Identified gaps in API authorization, security testing, logging, and monitoring are recorded.
- Corrective actions are assigned to responsible teams with defined priorities and follow-up deadlines.
- The incident response plan is updated to incorporate lessons learned from this event.

4. Internal Communication Plan

Timing	Audience	Purpose
Immediately after alert validation	Security / Incident Response Team & Internal Leadership	Confirm the incident, assign ownership, and coordinate the initial response.
During initial investigation	Legal / Compliance & Technical Owners	Discuss the nature, scope, available evidence, and applicable response obligations.
After impact is established	Affected Customers (where applicable)	Provide clear, factual information about the incident and any protective steps they should take.
As required by applicable law	Relevant Regulators / Authorities	Submit required incident notifications through the appropriate regulatory channel.

5. Preventative Measures

Measure 1: Enforce Server-Side Authorization

Every API request must verify the caller's authentication, authorization, and resource ownership before returning any customer data. Authorization logic must reside on the server — never relying solely on client-supplied identifiers.

Measure 2: Conduct Regular API Security Testing

Security testing should be performed against all customer-facing APIs before deployment and at regular intervals thereafter. Tests must specifically cover broken access-control scenarios, including attempts to access resources belonging to other users.

Measure 3: Improve Monitoring and Alerting

Centralized API and database logging should be configured to detect anomalous access patterns — such as unusually high query volumes or cross-account record access — and generate timely alerts for investigation by the security team.

6. Conclusion

This incident response plan provides a structured, phase-by-phase approach to managing a hypothetical customer data exposure resulting from an unsecured API endpoint. By maintaining response readiness, detecting suspicious activity early, containing and eradicating the root cause, restoring services safely, and applying lessons learned, NovaCart can minimize the impact of the incident and build a stronger security posture going forward.